

Vendor Access and Third-Party Risk Policy

Third-Party Access Governance

CONFIDENTIAL

Document ID
MIG-POL-005

Effective Date
October 15, 2025

Approved By
CISO and General Counsel

Review Cycle
Annual

Version
2.8

Document Owner
VP of Third-Party Risk Mgmt

Regulatory Alignment
NAIC MDL-668 Section 4H, OCC Guidance

Document Control

Revision History

Version	Date	Author	Changes	Approved By
2.8	Oct 2025	C. Davis, VP TPRM	Updated geo-access to 8 countries	CISO / GC
2.5	Apr 2025	C. Davis	Added remote support tool approvals	CISO / GC
2.2	Oct 2024	A. Wilson	Added vendor risk tiering framework	C. Davis
2.0	Apr 2024	A. Wilson	24-hour termination SLA added	C. Davis
1.0	Sep 2023	HR/Legal	Initial policy creation	CISO / GC

Approval Signatures

Role	Name	Signature	Date
Document Owner	VP of Third-Party Risk Mgmt	_____	October 15, 2025
CISO	CISO and General Counsel	_____	October 15, 2025
General Counsel	Legal Department	_____	October 15, 2025

Distribution

This document is distributed to all employees via the corporate policy portal, Information Security, IT Operations, Compliance and Risk Management, Legal, Internal Audit, and the Executive Leadership Team.

Related Documents

Document ID	Title	Relationship
MIG-POL-001	Acceptable Use Policy	Sibling
MIG-POL-002	Information Security Policy	Sibling
MIG-POL-003	Data Sharing and Transfer Policy	Sibling
MIG-POL-004	Network Security Standard	Technical Standard
MIG-POL-005	Vendor Access Policy	Sibling
MIG-STD-010	Encryption Standards	Technical Standard
MIG-STD-012	IAM Standard	Technical Standard

Table of Contents

1. Purpose and Scope
2. Vendor Classification and Risk Tiering
3. Access Provisioning Process
4. Authentication and Device Requirements
5. Geographic Access Policy
6. Remote Support Tools
7. Access Termination and Revocation
8. Ongoing Access Reviews
9. Vendor Security Incident Response
10. Sanctions and Geographic Restrictions

1. Purpose and Scope

This policy governs the provisioning, management, monitoring, and termination of network and application access for all third-party vendors, contractors, managed service providers, reinsurance partners, and business partners who require access to Meridian Insurance Group systems or data. It applies to all access methods including VPN, Zscaler Private Access (ZPA), direct API integration, SFTP, and temporary on-site network access.

This policy is subject to NAIC Insurance Data Security Model Law requirements for third-party service provider oversight (Section 4H) and OCC Guidance on Third-Party Risk Management. The Third-Party Risk Management (TPRM) Office is the policy owner and is responsible for enforcing vendor compliance.

2. Vendor Classification and Risk Tiering

All vendors are classified into risk tiers based on the sensitivity of data accessed and the criticality of systems involved:

Tier	Risk Level	Data Access	Security Requirements	Review Frequency
1	Critical	PII, PCI, claims data	SOC 2 Type II, pen test, DPA, insurance	Quarterly
2	High	Internal business data	SOC 2 Type II, DPA	Semi-annual
3	Medium	Non-sensitive systems	Security questionnaire, DPA	Annual
4	Low	Public data only	Standard T&C	Biennial

3. Access Provisioning Process

All vendor access must be provisioned through the Vendor Access Management (VAM) system. Access requests require three-party approval: (1) the business owner sponsoring the vendor, (2) the vendor's designated security contact, and (3) the Information Security team. Access is granted on a least-privilege basis and scoped to the minimum systems and data required for the contracted work.

Vendor accounts must use a standardized naming convention: vendor-[companyname]-[user]-ext. All vendor accounts must be created with an expiration date matching the contract end date. Standing access (no expiration) is prohibited for vendor accounts.

4. Authentication and Device Requirements

All vendor users must authenticate through Meridian Insurance Group's identity provider (Azure AD B2B or equivalent) using multi-factor authentication. SAML federation with the vendor's own IdP is permitted for Tier 1 vendors only, subject to IdP security assessment.

POLICY MANDATE: MIG-POL-005-AUTH01

Vendor devices must meet minimum device posture requirements before access is granted: (a) current antivirus/EDR agent installed and reporting, (b) full disk encryption enabled, (c) operating system patched within 30 days of latest security update, (d) no jailbroken or rooted mobile devices. Device posture is verified at each connection attempt through Zscaler Client Connector or equivalent endpoint agent.

5. Geographic Access Policy

Meridian Insurance Group recognizes that approved vendors operate from multiple global locations. Insurance is a global industry with reinsurance, actuarial, and technology partners operating across multiple countries:

POLICY MANDATE: MIG-POL-005-GEO01

Approved vendor personnel may access Meridian Insurance Group systems from **any non-sanctioned country where the vendor maintains a registered business presence**. Geographic restrictions in network access controls (including Zscaler ZPA, ZTNA policies, and conditional access rules) **must be configured to include all countries where approved vendors operate**. ZTNA policies that restrict access to only India and the United States are non-compliant with this policy and must be updated. Current approved vendor operating countries: **United States, India, United Kingdom, Singapore, Germany, Australia, Philippines, and Canada**. This list is maintained in the VAM system and updated as vendor contracts change.

6. Remote Support Tools

Vendors providing remote support, managed services, or system administration require remote access tools. The following tools are approved under specific conditions:

POLICY MANDATE: MIG-POL-005-RST01

Approved managed service providers may use **TeamViewer Corporate, AnyDesk Enterprise, or BeyondTrust Remote Support** for remote support sessions. All remote support sessions must be: (a) authenticated with MFA, (b) initiated only during a scheduled maintenance window or approved incident response, (c) supervised by a Meridian Insurance Group IT staff member, (d) recorded and logged in the SIEM, (e) limited to 4 hours maximum duration. Unsupervised remote access is prohibited. Network controls must not block these tools for authorized vendor users.

7. Access Termination and Revocation

CRITICAL REQUIREMENT: MIG-POL-005-TERM01

All network and application access for third-party vendors must be revoked within 24 hours of contract termination. The VAM system generates an automatic revocation ticket upon contract end-date. The Identity and Access Management (IAM) team must execute the revocation within the 24-hour SLA. Any vendor access remaining active more than 48 hours after contract termination constitutes a **Critical security violation** and must be reported to the CISO immediately. Zscaler ZPA application segments for terminated vendors must be disabled, not just the user accounts.

8. Ongoing Access Reviews

Review Type	Frequency	Responsible Party	Scope
Access recertification	Monthly	Business owner	Confirm all vendor users still need access
Security assessment	Per tier schedule	TPRM Office	SOC 2, pen test, questionnaire
Access log review	Weekly	SOC	Anomalous vendor activity, off-hours access
Contract alignment	Quarterly	TPRM Office	Verify access scope matches contract scope
Terminated vendor sweep	Monthly	IAM team	Identify and remove orphaned vendor accounts

9. Vendor Security Incident Response

If a vendor experiences a security incident that may affect Meridian Insurance Group data or systems, the vendor must notify Meridian Insurance Group's SOC within 2 hours of detection. The TPRM Office will assess impact and may immediately revoke all vendor access pending investigation.

POLICY MANDATE: MIG-POL-005-LOG01

All vendor access sessions, authentication events, and data transfer activities must be logged and forwarded to the corporate SIEM platform (Splunk) in real time via nanolog streaming. Logs must include: user identity, source IP, destination resource, action taken, timestamp, and session duration. Log retention for vendor activity is 7 years per NAIC requirements. The SOC must review vendor access logs weekly for anomalous patterns including off-hours access, unusual data volumes, and geographic anomalies.

10. Sanctions and Geographic Restrictions

POLICY MANDATE: MIG-POL-005-SANC01

Vendor access from OFAC-sanctioned countries is strictly prohibited regardless of vendor approval status. Network controls must block all access attempts originating from North Korea, Iran, Syria, and any other country designated by OFAC. This restriction cannot be overridden by vendor approval or business justification. Sanctions compliance takes precedence over all other access policies.

Vendors must cooperate fully with incident investigations and provide forensic evidence within 48 hours of request. Failure to report incidents or cooperate with investigations is grounds for immediate contract termination.

Appendix A: Definitions and Acronyms

Term	Definition
AES	Advanced Encryption Standard - symmetric block cipher
CASB	Cloud Access Security Broker
CISO	Chief Information Security Officer
DLP	Data Loss Prevention - technology to detect/prevent data exfiltration
IoT	Internet of Things - non-standard network-connected devices
MFA	Multi-Factor Authentication
NAIC	National Association of Insurance Commissioners
OFAC	Office of Foreign Assets Control
PCI DSS	Payment Card Industry Data Security Standard
PII	Personally Identifiable Information
SFTP	Secure File Transfer Protocol
SOC 2	Service Organization Control Type 2 audit
SSL/TLS	Secure Sockets Layer / Transport Layer Security
WAF	Web Application Firewall
ZPA	Zscaler Private Access
ZIA	Zscaler Internet Access
ZTNA	Zero Trust Network Access

Appendix B: Disclaimer

This document is the sole property of Meridian Insurance Group and contains confidential and proprietary information. It is intended exclusively for authorized personnel and must not be reproduced, distributed, or disclosed to third parties without prior written consent from the Chief Information Security Officer. This policy document is reviewed and updated according to the schedule defined in the Document Control section. Interim updates may be issued to address emerging threats, regulatory changes, or operational requirements. All employees and contractors are responsible for understanding and complying with this policy. Questions regarding interpretation or applicability should be directed to the Information Security Governance team.

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contract, and may also result in civil or criminal penalties under applicable laws and regulations.